

BASIC NOTIONS

Introduction to Computer and Network Security

Silvio Ranise [silvio.ranise@unitn.it or ranise@fbk.eu]



UNIVERSITÀ
DI TRENTO



- *-Security
 - Remarks on *-security
- The CIA triad
- Risk
- Security policies, mechanisms, and services
- Wrap-up

CONTENTS





2

SOME “DEFINITIONS”

- **Information security**

- the practice of preventing unauthorized access, use, disclosure, disruption, modification, inspection, recording or destruction of information. It is a general term that can be used **regardless of the form the data may take** (e.g., **electronic, physical**).

https://en.wikipedia.org/wiki/Information_security

- **Computer security**

- the protection of **computer systems and information** from harm, theft, and unauthorized use. Computer **hardware** is typically protected by the same means used to protect other valuable or sensitive equipment, namely, serial numbers, doors and locks, and alarms. The protection of **information** and system access, on the other hand, is achieved through other tactics, some of them quite complex.

<https://www.britannica.com/technology/computer-security>

- **Network security**

- Network Security is the process of taking **physical** and **software** preventative measures to protect the underlying **networking infrastructure** from unauthorized access, misuse, malfunction, modification, destruction, or improper disclosure, thereby creating a secure platform for computers, users and programs to perform their permitted critical functions within a secure environment.

<https://www.sans.org/network-security/>

3

CYBER-SECURITY

https://csrc.nist.gov/glossary/term/cyber_security

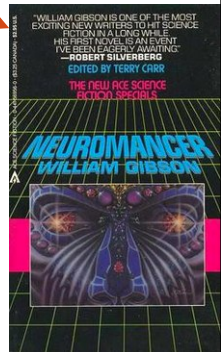
The ability to protect or defend the use of cyberspace from cyber attacks

A global domain within the information environment consisting of the interdependent network of information systems infrastructures including the Internet, telecommunications networks, computer systems, and embedded processors and controllers

A **cyber attack** [...] targeting an organization's use of cyberspace for the purpose of disrupting, disabling, destroying, or maliciously controlling a computing environment/infrastructure; or destroying the integrity of the data or stealing controlled information

https://csrc.nist.gov/glossary/term/cyber_attack

Alternative definition of cyberspace



4

REMARKS ON *-SECURITY (1)

- Security is characterized by protection **against an adversary** or, possibly, against some other physical or random process
- Security typically focuses on **malicious adversaries**
- Core to any consideration of security is the **modelling** of malicious adversaries
 - motivations (in the past... glory, nowadays... money)
 - capabilities (intercept messages, modify messages, read keys pressed, ...)
 - threats (roughly, negative impact on systems, operations, organization, business, ...)
- Arguing that a system is secure without referring to an attacker model does not make much sense
 - Example: a 0-day attack that exploits a previously unknown hardware, firmware, or software vulnerability (https://csrc.nist.gov/glossary/term/zero_day_attack)
- Indeed, absolute security does not exist even for so-called air-gapped system
 - Example: <https://spectrum.ieee.org/the-real-story-of-stuxnet>

5

REMARKS ON *-SECURITY (2)

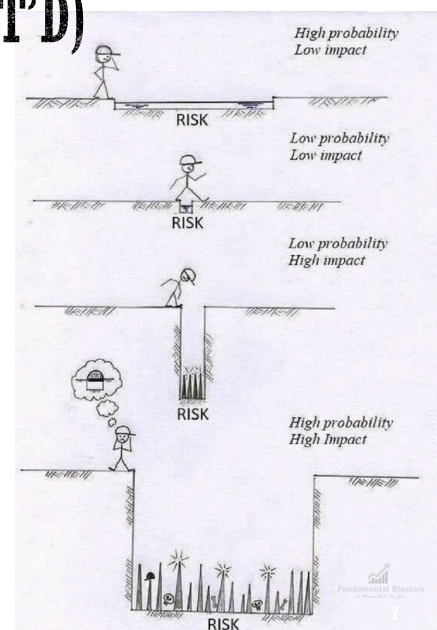
- In order to mitigate threats, security proposes **controls/mitigation strategies** affecting
 - people (e.g., rules for setting passwords)
 - process (e.g., regularly update software)
 - technology (e.g., authentication and access control)
- Controls can be classified in
 - **preventive**, i.e. before the bad event (e.g., locking out unauthorized intruders)
 - **detective**, i.e. during the bad event (e.g., turning an intruder alert on a dashboard)
 - **corrective**, i.e. after the bad event (e.g., recovering deleted data from a backup)
- Selection of controls is based on
 - **risk management**: the process of identifying vulnerabilities and threats to the information resources used by an organization and deciding what countermeasures, if any, to take in reducing risk to an acceptable level
 - considering the **human factor**: controls must be easy to use and must neither require stress of mind nor the knowledge of a long series of rules

6

REMARKS ON *-SECURITY (2 CONT'D)



https://dilbert.com/search_results?terms=Mordac%20The%20Preventer

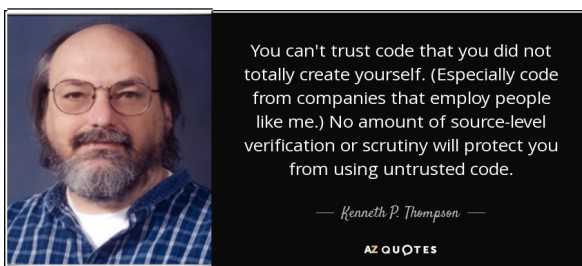


REMARKS ON *-SECURITY (3)

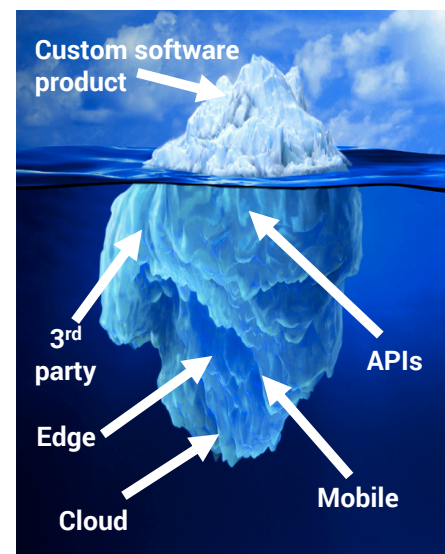
- The role of **trust** in software
 - **Dependability** = ability to avoid failures that are more frequent and severe than is acceptable
 - **Failure** = an event that occurs when the delivered service deviates from correct service
 - **Trust** = accepted dependence
 - For a complete discussion on dependability, trust, and security see
 - https://drum.lib.umd.edu/bitstream/handle/1903/6459/TR_2004-47.pdf
 - Example: *SolarWinds attack*
 - The attack compromises the infrastructure of SolarWinds, a company that produces a network and applications monitoring platform called Orion, and then uses that access to produce and distribute **trojanized updates** to the software's users (an instance of a supply chain attack)
 - A trojan is any malware (i.e. a software intentionally designed to cause damage) that misleads users of its true intent
 - Impact on 425 of the US Fortune 500, the top ten US telecommunications companies, the top five US accounting firms, all branches of the US Military, the Pentagon, the State Department, and hundreds of universities and colleges worldwide
- <https://www.csoonline.com/article/3601508/solarwinds-supply-chain-attack-explained-why-organizations-were-not-prepared.html>

8

REMARKS ON *-SECURITY (3 CONT'D)



Thompson's Turing Award Lecture in 1984 entitled "Reflections on Trusting Trust":
To what extent should one trust a statement that a program is free of Trojan horses? Perhaps it is more important to trust the people who wrote the software.



REMARKS ON *-SECURITY (4)

- Security controls are human artifacts that
 - can mitigate the impact of an attack but in many cases **do not avoid it completely**
 - **can contain vulnerabilities** that can be exploited to mount attacks
- In other words, we are left with a (non-null) **residual risk**, i.e. the amount of danger associated with an attack after risks have been mitigated by security controls
- Example: automotive seat-belts
 - Use of seat-belts reduces the the risk of injury although it does not cancel it as
 - accidents may be quite serious and seat-belts can only mitigate consequences
 - installation of set-belts may be defective and mitigation of risk is reduced

10

REMARKS ON *-SECURITY (5)

“Exploiting vulnerabilities allows attackers to violate security”

- At first reading, this may seem obvious but is it really so?
- What does it mean exactly to “violate security”?
- There many possibly answers to the question above including
 - A security violation can be the unauthorized sharing of sensitive information such as personal data of patients in a healthcare system
 - A security violation can be the unauthorized modification of the content of a resource such as modifying the balance of bank account
 - A security violation can be the unauthorized withholding of the content of a resource or service such as the unavailability of network services
- The three answers correspond to three crucial properties characterizing three possible dimensions of security
 - They are collectively known as ...

11



THE CIA TRIAD

Characterizing security or guiding the selection and use of security controls

SECURITY PROPERTIES

- Confidentiality
 - prevent un-authorised disclosure of information
 - permit authorized sharing of information
- Integrity
 - prevent un-authorised modification of information
 - permit authorized modification of information
- Availability
 - prevent un-authorised withholding of information or services
 - readily permit authorized access to information or services

The CIA triad



CONFIDENTIALITY: SOME DEFS FROM NIST

- Preserving authorized restrictions on information access and disclosure, including means for **protecting personal privacy and proprietary information**.
- The property that sensitive information is not disclosed to unauthorized individuals, entities, or processes.
- The security goal that generates the requirement for protection from intentional or accidental attempts to perform **unauthorized data reads**. Confidentiality covers data **in storage, during processing, and while in transit**.
- The property that sensitive information is not disclosed to unauthorized entities. In a general **information security context**: preserving authorized restrictions on information access and disclosure, including means for preserving personal privacy and proprietary information.

<https://csrc.nist.gov/Glossary/?term=3591>

14

INTEGRITY: SOME DEFS FROM NIST

- Guarding against improper information **modification** or **destruction**, and includes ensuring information **non-repudiation** and **authenticity**.
- The property that sensitive data has not been modified or deleted in an unauthorized and undetected manner.
- The ability to detect even **minute changes** in the data.
- Ensuring the authenticity of information—that information is not altered, and that the source of the information is genuine.
- The security objective that generates the requirement for protection against either intentional or accidental attempts to violate **data integrity** (the property that data has not been altered in an unauthorized manner) or **system integrity** (the quality that a system has when it performs its intended function in an unimpaired manner, free from unauthorized manipulation).

<https://csrc.nist.gov/Glossary/?term=4875#AlphaIndexDiv>

15

INTEGRITY: SOME DEFS FROM NIST

- Guarding against improper alteration of information, ensuring information **non-repudiation**.
 - The property that sensitive information is not altered by unauthorized and undetectable means.
 - The ability to detect even minor changes to information.
 - Ensuring the authenticity of information and the source of the information.
 - The security objective that information is not altered intentionally or accidentally and that a system has when it performs its function free from unauthorized manipulation.
- Authenticity
 - The property of being genuine and being able to be verified and trusted; confidence in the validity of a transmission, a message, or message originator.
 - Non-repudiation (auditability)
 - Protection against an individual falsely denying having performed a particular action. Provides the capability to determine whether a given individual took a particular action such as creating information, sending a message, approving information, and receiving a message.

<https://csrc.nist.gov/Glossary/?term=4875#AlphaIndexDiv>

16

AVAILABILITY: SOME DEFS FROM NIST

- Ensuring **timely and reliable** access to and use of information.
- Timely, reliable access to **data** and **information services** for **authorized** users.
- The ability for **authorized** users to **access systems** as needed.
- A requirement intended to assure that systems **work promptly** and service is **not denied to authorized users**.
- The security goal that generates the requirement for protection against intentional or accidental attempts to (1) perform unauthorized deletion of data or (2) otherwise cause a **denial of service or data**.

<https://csrc.nist.gov/Glossary/?term=3103#AlphaIndexDiv>

17



RISK



There is no such thing as perfect security, only varying levels of insecurity.

— Salman Rushdie —

AZ QUOTES

"Things are not quite so simple always as Black and White" – Doris Lessing

VULNERABILITY

- Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source.
- A weakness in a system, application, or network that is subject to exploitation or misuse.
- A flaw or weakness in a computer system, its security procedures, internal controls, or design and implementation, which could be exploited to violate the system security policy.

<https://csrc.nist.gov/Glossary/?term=2436#AlphaIndexDiv>



SOME EXAMPLES OF VULNERABILITIES

- Hidden backdoors

- Example: Huawei equipment (<https://www.bloomberg.com/news/articles/2019-04-30/vodafone-found-hidden-backdoors-in-huawei-equipment>)

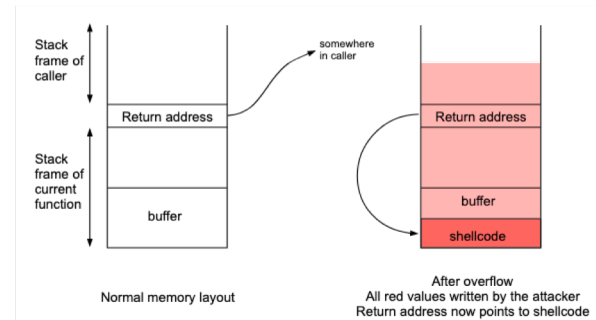
- Unknown software bugs

- Example: buffer overflow/overrun

- Weak passwords

<https://koofr.eu/blog/posts/worst-passwords-of-2020>

Position	Password	Number of users	Time to crack it	Times exposed
1. ↑ (2)	123456	2,543,285	Less than a second	23,597,311
2. ↑ (3)	123456789	961,435	Less than a second	7,870,694
3. (new)	picture1	371,612	3 Hours	11,190
4. ↑ (5)	password	360,467	Less than a second	3,759,315
5. ↑ (6)	12345678	322,187	Less than a second	2,944,615



<http://intronetworks.cs.luc.edu/currentl/uhtml/security.html>

20

THREAT

- Any circumstance or event with the potential to **adversely impact** organizational operations (including mission, functions, image, or reputation), organizational assets, or individuals through an information system **via unauthorized access, destruction, disclosure, modification of information, and/or denial of service**. Also, the potential for a threat-source to successfully **exploit a particular information system vulnerability**.
- An activity, deliberate or unintentional, with the potential for causing harm to an automated information system or activity.
- The potential for a threat-source to exercise (**accidentally trigger or intentionally exploit**) a specific **vulnerability**.

<https://csrc.nist.gov/Glossary/?term=2156#AlphaIndexDiv>

21

SOME EXAMPLES OF THREATS

- Hackers
 - Break a password or sniff it off the network
 - Use social engineering to get a password
 - Taking up resources with irrelevant messages
 - **Denial-of-service** attacks aim to disrupt a service by either exploiting a vulnerability or by sending a lot of bogus messages to a computer offering a service
- Viruses and some worms
 - A **virus** is a self-replicating program that requires user action to activate such as clicking on Email, downloading an infected file or inserting an infected floppy, CD, etc ..
 - A **worm** is a self-replicating program that does not require user action to activate. It propagates itself over the network, infects any vulnerable machine it finds and then spreads from it further.

22

RISK

- The **probability** that a particular security **threat** will **exploit** a system **vulnerability**.
- A measure of the extent to which an entity is threatened by a potential circumstance or event, and typically **a function of**: (i) the **adverse impacts** that would arise if the circumstance or event occurs; and (ii) the **likelihood of occurrence**.

Note: Information system-related security risks are those risks that arise from the **loss of confidentiality, integrity, or availability** of information or information systems and reflect the **potential adverse impacts to organizational** operations (including mission, functions, image, or reputation), organizational assets, **individuals, other organizations**, and the **Nation**. Adverse impacts to the Nation include, for example, compromises to information systems that support critical infrastructure applications or are paramount to government continuity of operations as defined by the Department of Homeland Security.

<https://csrc.nist.gov/Glossary/?term=1013#AlphaIndexDiv>

23

REMARKS ON RISK

- Risk is the result of **threats exploiting vulnerabilities to obtain, damage, or destroy resources** together with their **impact on** the properties in the **CIA triad**
- **Threats** can be characterized as a combination of
 - **intent** = propensity to attack
 - **capability** = ability to successfully attack
- Vulnerabilities are characterized by how easy it is to
 - **identify** them
 - **exploit** them
- Threats and vulnerabilities give the **likelihood** that an adverse event may happen
- Impact should be evaluated with respect to each **stakeholder** that has an interest in the system under consideration
 - Example: unauthorised disclosure of personal information may have catastrophic consequence for the patients involved in the data breach but can be negligible for the organization offering the healthcare service if the number of patients involved is low

24

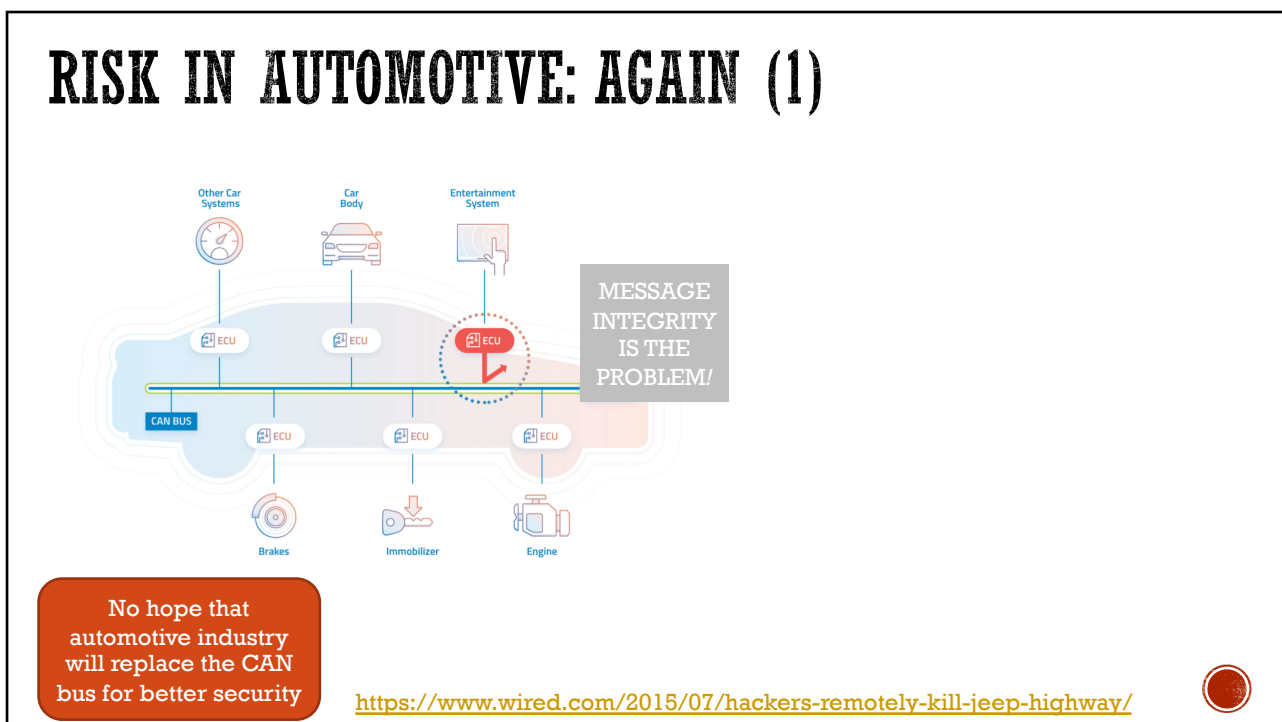
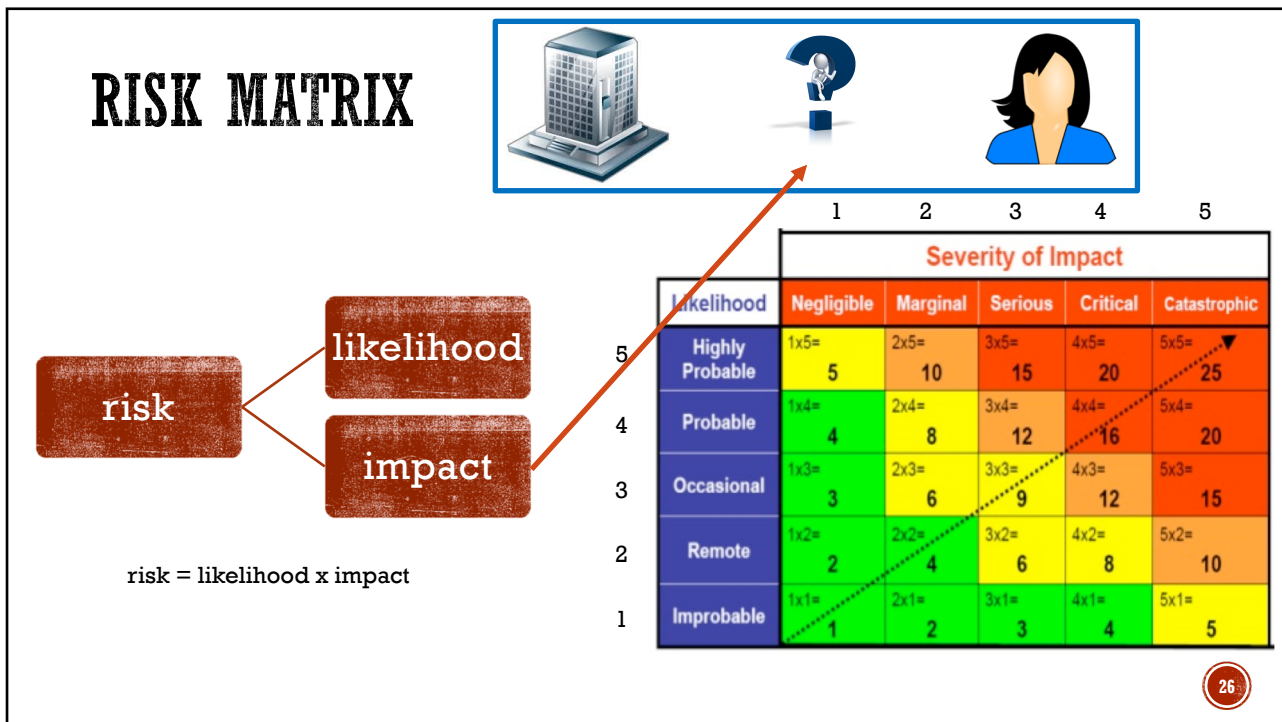
A REMARK ON IMPACT

- Nowadays, computers are everywhere and the impact of attacks can be substantial
- Example
 - Automotive attacks can lead to important consequences both on the vehicles and the passengers
 - For the 2015 attack on a FCA jeep, impact was substantial for all stakeholders
 - Manufacturer obliged to recall 1.4 millions vehicles
 - Drivers and passengers safety put at risk

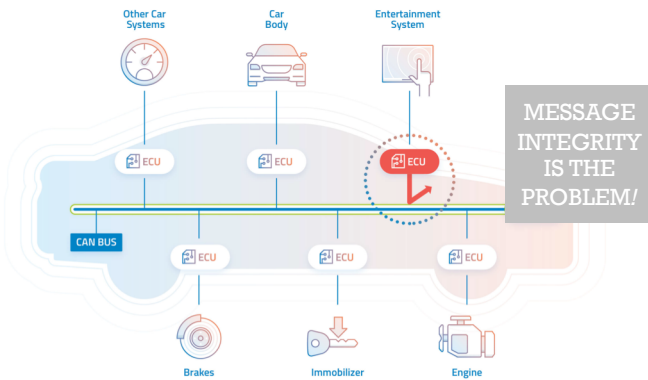


<https://money.cnn.com/2015/07/24/technology/chrysler-hack-recall/index.html?sr=twmoney072415chrysler900story>

25



RISK IN AUTOMOTIVE: AGAIN (2)



No hope that automotive industry will replace the CAN bus for better security

<https://www.wired.com/2015/07/hackers-remotely-kill-jeep-highway/>

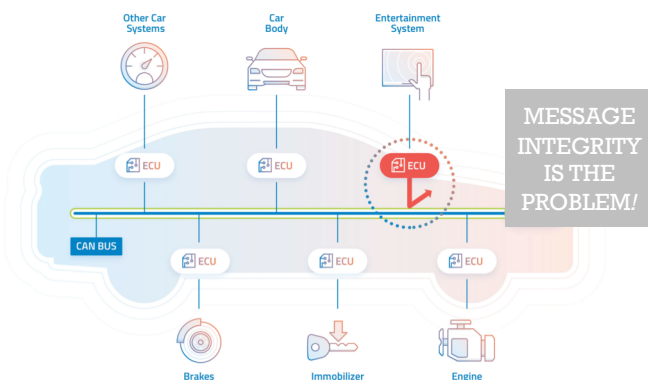
Likelihood



Wireless carjacking of a Jeep (2015)



RISK IN AUTOMOTIVE: AGAIN (3)



No hope that automotive industry will replace the CAN bus for better security

<https://www.wired.com/2015/07/hackers-remotely-kill-jeep-highway/>

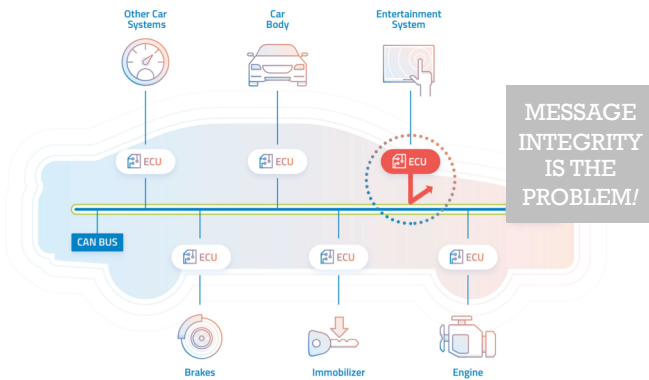
Impact



Wireless carjacking of a Jeep (2015)



RISK IN AUTOMOTIVE: AGAIN (4)



No hope that automotive industry will replace the CAN bus for better security

<https://www.wired.com/2015/07/hackers-remotely-kill-jeep-highway/>



Impact

Fiat Chrysler recalls 1.4 million cars after Jeep hack

© 24 July 2015

Share



Jeep's Grand Cherokee is one of the recalled cars

Fiat Chrysler has issued a safety recall affecting 1.4m vehicles in the US, after security researchers showed that one of its cars could be hacked.

Wireless carjacking of a Jeep (2015)



SECURITY POLICIES AND MECHANISMS

SECURITY POLICY, SERVICE & MECHANISM

- **Security policy**

- The rules and requirements established by an organization that governs the acceptable use of its information and services, and the level and means for protecting the confidentiality, integrity, and availability of its information

<https://csrc.nist.gov/Glossary/?term=1268#AlphaIndexDiv>

- **Security mechanism**

- A device or function designed to provide one or more security services usually rated in terms of strength of service and assurance of the design.
- Implementation of a security policy

<https://csrc.nist.gov/Glossary/?term=1262#AlphaIndexDiv>

- **Security service**

- A capability that supports one, or more, of the security requirements (Confidentiality, Integrity, Availability). Examples of security services are key management, access control, and authentication.

<https://csrc.nist.gov/Glossary/?term=1268#AlphaIndexDiv>

32

EXAMPLE OF SECURITY POLICY

- **Purpose**

- <Company X> must protect restricted, **confidential or sensitive data from loss** to avoid reputation damage and to avoid adversely **impacting** customers. The primary objective is user awareness and to avoid accidental loss scenarios (data leakage prevention)

- **Scope**

- Any employee, contractor or individual with access to <Company X> systems or data.
- Definition of data to be protected
 - Personal data
 - Financial
 - Intellectual Property

Try to answer the question:
What does it mean for
Company X
“confidential/sensitive
data”?

Adapted from <https://www.sophos.com/en-us/medialibrary/PDFs/other/sophos-example-data-security-policies-na.pdf?la=en>

33

EXAMPLE OF SECURITY POLICY (CONT'D)

- Policy rules

1. Employees need to complete <Company X>'s security awareness training and agree to uphold the acceptable use policy.
2. Visitors to <Company X> must be escorted by an authorized employee at all times. If an employee is responsible for escorting visitors, he/she must restrict them to appropriate areas.
3. Employees must keep a clean desk. To maintain information security, employees need to ensure that all printed in scope data is not left unattended.
4. Employees need to use a secure password on all <Company X> systems **as per the password policy**. These credentials must be unique and must not be used on other external systems or services.
5. Terminated employees will be required to return all records, in any format, containing personal information.

Adapted from <https://www.sophos.com/en-us/medialibrary/PDFs/other/sophos-example-data-security-policies-na.pdf?la=en>

34

FEW EXAMPLES OF SECURITY MECHANISM

- Authentication

- Verifying the identity of a **user, process, or device**, often as a **prerequisite to allowing access** to resources in an information system.

<https://csrc.nist.gov/Glossary/?term=3052#AlphaIndexDiv>

- Authorization

- The granting or denying of access rights to a user, program, or process.

<https://csrc.nist.gov/Glossary/?term=3081#AlphaIndexDiv>

- Access control

- The process of granting or denying specific requests: 1) obtain and use information and related information processing services; and 2) enter specific physical facilities (e.g., Federal buildings, military establishments, border crossing entrances).

<https://csrc.nist.gov/Glossary/?term=2785#AlphaIndexDiv>

35

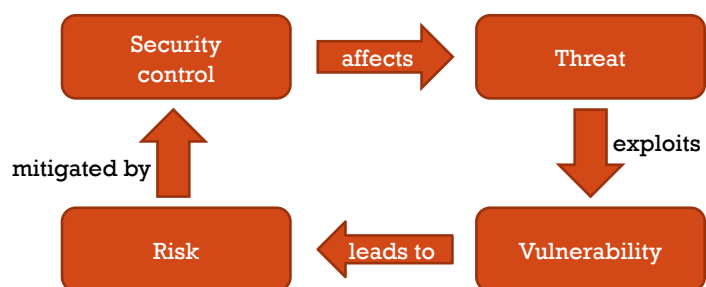
WRAP-UP (1)



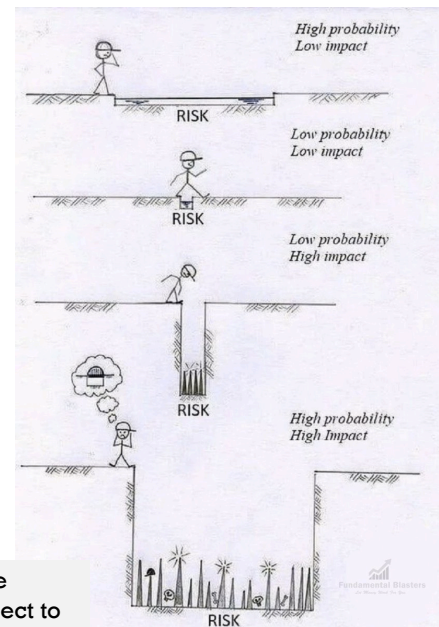
- For every use case scenario, the CIA should be carefully instantiated
- Security policies can be used to specify CIA properties
- Security mechanisms and services can be used to enforce security policies (i.e. ultimately to enforce CIA)

36

WRAP-UP (2)



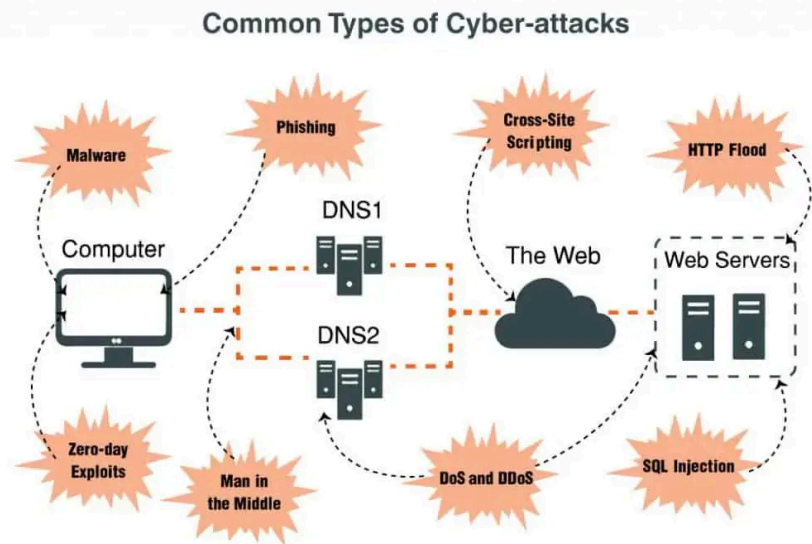
The impact should be considered with respect to the different stakeholders



37

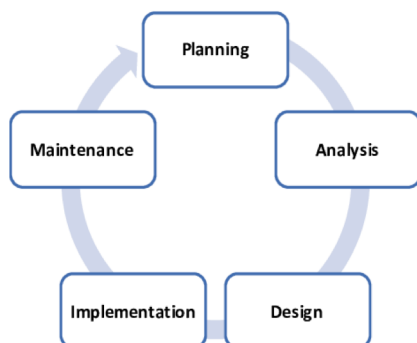
WRAP-UP (3)

Security should consider the capabilities of attackers or threats to defend against

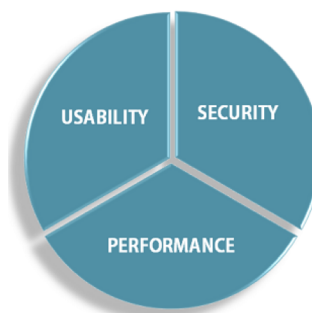


WRAP-UP (4)

Software development life cycle



Interplay with usability and performance



Security should be considered in a rich and complex context with many different aspects...

Human and organization factors

